

# What Is Vulnerability Assessment? Benefits, Tools, and Process

## What Is a Vulnerability Assessment?

A vulnerability assessment helps identify, classify, and prioritize vulnerabilities in network infrastructure, computer systems, and applications. A vulnerability is a security weaknesses that might expose the organization to cyber threats or risks. Vulnerability assessments often employ automated testing tools such as network security scanners, showing the results in a vulnerability assessment report.

Organizations facing ongoing cyber attacks can greatly benefit from regular vulnerability assessments. Threat actors constantly look for vulnerabilities they can exploit to breach applications, systems, and possibly entire networks. New vulnerabilities are discovered all the time in existing software and hardware components, and organizations also introduce new components on a regular basis. A vulnerability assessment coupled with a vulnerability management program can help identify and fix security weaknesses and improve security posture.

This is part of an extensive series of guides about [hacking](#).

## The Importance of Vulnerability Assessment

The most common security vulnerabilities are rooted either in technology issues or user behavior:

- Breaches can occur if insiders accidentally expose information to an external source or leak information intentionally (i.e., malicious insiders).
- Lost and stolen devices that contain unencrypted data are also a major vector for infiltration into a company's network.
- Cybercriminals can install malware on target systems to exfiltrate data or gain control over computing systems.

Vulnerability management helps companies prevent data breaches and leaks, but it requires continuous vigilance. The process is ongoing and involves conducting periodic vulnerability assessments - when one assessment completes, another must begin.

Vulnerability assessments allow security teams to identify, analyze, categorize, report, and remediate security vulnerabilities in operating systems, business applications, endpoint devices, and browsers.

Organizations discover thousands of new vulnerabilities each year, requiring constant patching and reconfiguration to protect their networks, applications, and operating systems. However, many companies lack an effective patch management strategy and don't apply the necessary patches in time to prevent a breach.

It is impractical to patch all vulnerabilities immediately. A vulnerability management system helps prioritize vulnerabilities and ensure the security team addresses high-risk vulnerabilities first. Vulnerability management encompasses the tooling and processes needed to find and remediate the most critical vulnerabilities regularly.

## Types of Vulnerability Assessment Tools

Modern vulnerability assessments rely on automated scanning tools. Here are the main categories of tools used to scan an environment for vulnerabilities:

- **Network-based scanning**—used to identify potential network security attacks. This type of scan can also detect vulnerable systems on wired or wireless networks.
- **Host-based scanning**—used to identify vulnerabilities on servers, workstations, or other network hosts. This type of scan looks for vulnerable open ports and services, providing insights about the configuration settings and patch history of scanned systems.
- **Wireless network scans**—used to scan an organization's Wi-Fi network to identify security weaknesses. These scans can identify malicious access points and ensure that wireless networks are configured securely.
- **Application scans**—used to test websites and mobile applications for known software vulnerabilities and misconfigurations.
- **Database scans**—used to identify vulnerabilities that might allow database-specific attacks like SQL and NoSQL injection, as well as general vulnerabilities and misconfigurations in a database server.

## 5-Step Vulnerability Assessment Process

### 1. Initial Preparation

In this stage, the team decides the scope and goals of vulnerability testing. This involves:

- Identifying protected assets and equipment and mapping out all endpoints.
- Determining the business value of each asset and the impact if it is attacked.
- Identifying access controls and other security requirements of each system.
- Determining if systems hold sensitive data, and how sensitive data is transferred between systems.
- Recording a baseline of services, processes, and open ports on protected assets.
- Determining operating systems and software deployed on assets.

This information can help security teams understand the attack surfaces and the most severe threat scenarios, and develop a remediation strategy.

## 2. Vulnerability Assessment Testing

In this stage, the team runs automated vulnerability scans on target devices and environments. If necessary, they use manual tools to investigate the security posture of a system.

In order to automate this stage and make it more efficient, teams will typically rely on one or more vulnerability databases, vendor security advisories, and threat Intelligence feeds.

A single test can take anywhere from a minute to several hours, depending on the size of the target system and the type of scan.

## 3. Prioritize Vulnerabilities

At this stage, the team removes false positives from vulnerability scanning results and prioritize vulnerabilities according to several factors. These can include:

- Severity score provided by a vulnerability database
- The business impact if a vulnerability is exploited
- Sensitive data that might be at risk
- The ease of exploiting the vulnerability
- How long the vulnerability has been in place
- The ability to perform lateral movement from this system to other sensitive systems
- The availability of a patch and the effort needed to deploy it

## 4. Create a Vulnerability Assessment Report

At this stage, the team creates a unified report showing vulnerabilities found in all protected assets, with a plan for remediating them.

For medium to high risk vulnerabilities, the report should provide information about the vulnerability, when it was discovered, which systems it affects, the potential damage if attackers exploit it, and the plan and effort required to remediate it.

Where possible, the team should also provide a proof of concept (PoC) demonstrating how each critical vulnerability could be exploited.

## 5. Continuous Vulnerability Assessment

Vulnerability scans provide a point-in-time snapshot of vulnerabilities that exist in an organization's digital infrastructure. However, new deployments, configuration changes, newly discovered vulnerabilities, and other factors can result in new vulnerabilities. Because vulnerabilities are not static, vulnerability management should also be a continuous process.

Software development teams should incorporate automated vulnerability assessment into their continuous integration and deployment (CI/CD) pipeline. This allows vulnerabilities to be identified and fixed as early as possible in the software development lifecycle (SDLC), eliminating the need to develop and release patches for vulnerable code.

However, because this process cannot catch all vulnerabilities, and many vulnerabilities occur in legacy or third-party systems, it must be complemented by continuous vulnerability scans of production systems.

## Conclusion

In this article, we explained the basics of vulnerability assessment, covered the main tools that can be used to identify vulnerabilities, including network scanning, host scanning, and application scanning, and presented a 5-step process for managing vulnerability assessments in your organization:

- **Initial preparation** - defining scope and goals of vulnerability testing.
- **Vulnerability testing** - running automated tests to identify vulnerabilities in systems included in the scope.
- **Prioritize vulnerabilities** - identify which vulnerabilities are important and require attention, and their possible business impact.
- **Create vulnerability assessment report** - produce a plan detailing the medium and high priority vulnerabilities found and recommended remediations.

- **Continuous vulnerability assessment** - scanning for vulnerabilities on a continuous basis to see if previous vulnerabilities were remediated and discover new ones.

## Learn More About Vulnerability Assessment

### Vulnerability Management: 4 Steps to Successful Remediation

Vulnerability management is the practice of identifying, analyzing, and remediating hardware or software defects that attackers can exploit to carry out cyber attacks. Understand the basics of vulnerability management and discover a 4-step process to protecting your organization against harmful vulnerabilities.

Read more: [Vulnerability Management: 4 Steps to Successful Remediation](#)

### What is Vulnerability Scanning?

Vulnerability scanning uses an application (vulnerability scanner) to scan for security weaknesses in computers, networks, and other communications equipment in a system. Learn how vulnerability scanning works, why you need to do it, and how to do it right.

Read more: [What is Vulnerability Scanning?](#)

### Vulnerability Testing and Best Techniques for Assessing Risks

Vulnerability testing, also known as vulnerability assessment, evaluates an entire system to look for security weaknesses and vulnerabilities. Curious about vulnerability testing techniques? We explain processes such as vulnerability assessments, vulnerability scanning, and penetration testing.

Read more: [Vulnerability Testing and Best Techniques for Assessing Risks](#)

### Vulnerability Remediation: A Step-by-Step Guide

Vulnerability remediation is the process of addressing system security weaknesses. Are you wondering about vulnerability remediation? We give you a step-by-step guide to addressing vulnerabilities in your system.

Read more: [Vulnerability Remediation: A Step-by-Step Guide](#).

## See Our Additional Guides on Key Cybersecurity Topics

Together with our content partners, we have authored in-depth guides on several other topics that can also be useful as you explore the world of [Cybersecurity](#).

### [Attack Surface](#)

- [What Are Attack Vectors and 8 Ways to Protect Your Organization](#)

- [What Is Attack Surface Management and a 5-Step ASM Process](#)
- [What Is External Attack Surface Management \(EASM\)? | HackerOne](#)

## DevSecOps

- [The SecOps Transformation and Your SOC](#)
- [DevOps Security: Challenges and 6 Critical Best Practices](#)

## Command Injection

*Authored by Bright Security*

- [Code Injection Example: A Guide to Discovering and Preventing attacks](#)
- [PHP Code Injection: Examples and 4 Prevention Tips](#)

### Company

Leadership

Careers

Partners

Newsroom

Contact Us

### Knowledge

#### Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

### Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted  
by a  hacker?

Trust